

Module 04 — Enumeration (CEH v13)

Cours complet expliqué en français

Document pédagogique basé sur le PDF « CEHv13 - Module 04 - Enumeration » d'EC-Council (certification CEH, examen 312-50). Ce document reprend et explique tout le contenu du module, objectif par objectif.

Objectifs d'apprentissage

À la fin de ce module, vous serez capable de :

1. **Expliquer les concepts d'énumération** (enumeration concepts)
2. **Démontrer différentes techniques d'énumération NetBIOS**
3. **Démontrer différentes techniques d'énumération SNMP et LDAP**
4. **Utiliser différentes techniques d'énumération NTP et NFS**
5. **Démontrer différentes techniques d'énumération SMTP et DNS**
6. **Démontrer l'énumération IPsec, VoIP, RPC, Unix/Linux et SMB**
7. **Expliquer les contre-mesures d'énumération**

Contexte : après le footprinting (Module 02) et le scanning réseau (Module 03), l'attaquant passe à la phase suivante : l'énumération. L'attaquant établit des connexions **actives** avec le système cible et envoie des requêtes dirigées (directed queries) pour extraire des informations détaillées.

L'énumération fournit la matière première (noms d'utilisateurs, partages, services) qui permet de mener des attaques de mots de passe et d'obtenir un accès non autorisé. Les techniques d'énumération fonctionnent dans un environnement **intranet**.

Objectif 01 — Concepts d'énumération

1.1 Qu'est-ce que l'énumération ?

Définition : l'énumération est le processus d'extraction de **noms d'utilisateurs**, de **noms de machines**, de **ressources réseau**, de **partages** (shares) et de **services** à partir d'un système ou d'un réseau.

- L'attaquant crée des **connexions actives** avec la cible et envoie des **requêtes dirigées**.
- Les informations collectées servent à identifier les vulnérabilités et à préparer des **attaques de mots de passe** pour obtenir un accès non autorisé aux ressources.
- Les techniques d'énumération fonctionnent dans un environnement intranet.

Informations énumérées par les intrus :

Informations
Ressources réseau (network resources)
Partages réseau (network shares)
Tables de routage (routing tables)
Paramètres d'audit et de service (audit and service settings)
Détails SNMP et FQDN (fully qualified domain name)
Noms de machines (machine names)
Utilisateurs et groupes (users and groups)

À savoir : lors de l'énumération, les attaquants peuvent tomber sur un partage IPC (inter-process communication) distant, tel que **IPC\$** sous Windows. Ils peuvent alors le sonder pour se connecter à un partage administratif en **brute-forçant les identifiants admin** et obtenir la liste complète du système de fichiers représenté par le partage.

1.2 Légalité de l'énumération

- Les modules précédents (footprinting, scanning) montraient comment recueillir des informations sans activité illégale.
- **L'énumération, elle, peut être illégale** selon les politiques de l'organisation et les lois en vigueur.
- Un hacker éthique / pentester doit **toujours obtenir une autorisation appropriée** avant d'effectuer l'énumération.

1.3 Techniques d'énumération

1. **Extraire les noms d'utilisateurs à partir des adresses e-mail** — toute adresse e-mail a le format `username@domainname`.
2. **Extraire des informations via les mots de passe par défaut** — de nombreuses ressources en ligne listent les mots de passe par défaut des fabricants ; les utilisateurs négligent souvent de les changer.
3. **Brute force Active Directory** — l'Active Directory Microsoft est vulnérable à l'énumération des noms d'utilisateurs lors de la vérification des entrées utilisateur (défaut de conception). Si la fonction « logon hours » est activée, toutes les tentatives d'authentification d'un service génèrent des messages d'erreur différents → l'attaquant distingue les noms d'utilisateurs valides puis mène une attaque par brute force sur les mots de passe.
4. **Extraire des informations via le DNS Zone Transfer** — l'administrateur utilise le transfert de zone pour répliquer les données DNS entre serveurs. Si le serveur DNS n'est pas correctement configuré, le transfert de zone peut révéler tous les hôtes nommés, les sous-zones et les IP associées. Outils : `nslookup` et `dig`.
5. **Extraire les groupes d'utilisateurs Windows** — l'attaquant doit disposer d'un ID enregistré d'utilisateur dans l'AD, puis extraire les informations des groupes via l'interface Windows ou la ligne de commande.
6. **Extraire les noms d'utilisateurs via SNMP** — les attaquants devinent facilement les **community strings** en lecture seule ou lecture/écriture (public/private) via l'API SNMP.
7. **Extraire les ressources réseau et la topologie via SNMP** — les attaquants interrogent méthodiquement l'arbre SNMP (MIB tree) pour obtenir des détails sur les ressources et la topologie réseau.

1.4 Services et ports à énumérer

TCP est un protocole **orienté connexion** (transport de messages/e-mails). Fonctionnalités : accusé de réception par fenêtre glissante, retransmission automatique des données perdues, adressage et multiplexage, établissement/gestion/termination de connexions, qualité de service, gestion de congestion et contrôle de flux.

UDP est un protocole **sans connexion** (transport de messages courts) qui fournit un service **non fiable**. Applications : streaming audio, visioconférence et téléconférence.

Port	Service / protocole	Notes
TCP/UDP 53	DNS Zone Transfer	Les clients DNS utilisent UDP 53 par défaut ; TCP 53 en repli (failover) si la réponse dépasse 512 octets (indicateur de troncature). Malwares : ADM worm et Bonk Trojan utilisent le port 53.
TCP/UDP 135	Microsoft RPC Endpoint Mapper	RPC = protocole client→serveur. Un défaut de gestion des messages malformés sur RPC Endpoint Mapper permet des attaques DoS .
UDP 137	NetBIOS Name Service (NBNS / WINS)	Service de résolution de noms NetBIOS. Les attaquants attaquent le service de noms en premier.
TCP 139	NetBIOS Session Service (SMB over NetBIOS)	Port Windows le plus connu : transfert de fichiers, sessions nulles (null sessions), partage de fichiers et d'imprimantes. Une mauvaise configuration peut donner un accès non autorisé à tout le système de fichiers.
TCP/UDP 445	SMB over TCP (Direct Host)	SMB directement hébergé sur TCP, sans NetBIOS (NBT).
UDP 161 / UDP 162	SNMP (agent) / SNMP Trap	L'agent écoute sur le port 161, les réponses/traps partent vers le port 162 du gestionnaire.
TCP/UDP 389	LDAP	Accès aux services d'annuaire distribués.
TCP 2049	NFS (Network File System)	Montage de systèmes de fichiers distants ; si mal configuré : contrôle à distance, escalade de privilèges, backdoors.
TCP 25	SMTP	Commandes VRFY, EXPN, RCPT TO... utilisables pour l'énumération.
UDP 500	ISAKMP/IKE	Établissement, négociation, modification et suppression des Security Associations (SA) et clés cryptographiques dans les VPN IPsec.
TCP 22	SSH/SFTP	SSH : gestion sécurisée d'équipements ; SFTP : échange sécurisé de données sur un seul port (plus simple que FTP/S). Ataquants : brute-force SSH, énumération SFTP (comptes, permissions, configuration).
TCP/UDP 3268	Global Catalog Service	Serveur de catalogue global (contrôleur de domaine) : contient des lignes pour tous les objets de l'organisation. Administrateurs : dépannage via LDAP.
TCP/UDP 5060, 5061	SIP (Session Initiation Protocol)	Téléphonie IP (voix/vidéo). 5060 = signalisation non chiffrée, 5061 = chiffrée (TLS).
TCP 20/21	FTP	21 = contrôle, 20 = données. Énumération : version du logiciel et état des vulnérabilités ; attaques : sniffing et brute-force FTP.
TCP 23	Telnet	Non sécurisé (identifiants en clair). Ataquants : banner grabbing (SSH, SMTP), brute-force, port forwarding.
UDP 69	TFTP	Protocole sans connexion pour mise à jour de firmware ; les attaquants peuvent installer des logiciels malveillants.
TCP 179	BGP	Routage Internet ; mauvaise configuration → attaques par dictionnaire, épuisement de ressources, flooding, hijacking.

1.5 Commandes SMTP à connaître

Commande	Syntaxe	Rôle
Hello	HELO <sending-host>	Salutation
Mail	MAIL FROM:<from-address>	Expéditeur
Recipient	RCPT TO:<to-address>	Destinataire
Data	DATA	Données du message

Commande	Syntaxe	Rôle
Reset	RESET	Réinitialisation
Verify	VERFY <string>	Vérification
Expand	EXPN <string>	Développement
Help	HELP [string]	Aide
Quit	QUIT	Déconnexion

Objectif 02 — Techniques d'énumération NetBIOS

2.1 Présentation de NetBIOS

- **NetBIOS** a été développé à l'origine comme **API** permettant au logiciel client d'accéder aux ressources d'un réseau local (LAN).
- Windows utilise NetBIOS pour le **partage de fichiers et d'imprimantes**.
- Un **nom NetBIOS** est une chaîne ASCII unique de **16 caractères** : 15 caractères pour le nom de l'appareil, le 16e est réservé au **type de service ou d'enregistrement**.
- **Ports NetBIOS** : UDP 137 (services de noms), UDP 138 (services de datagrammes), TCP 139 (services de session).
- **Attention** : Microsoft ne prend **pas en charge** la résolution de noms NetBIOS pour **IPv6**.
- Les attaquants ciblent souvent NetBIOS car il est facile à exploiter et fonctionne sur les systèmes Windows même lorsqu'il n'est pas utilisé.

Informations obtenues via l'énumération NetBIOS : la liste des ordinateurs d'un domaine, la liste des partages des hôtes du réseau, les politiques et les mots de passe.

Table 4.2 — Liste des noms NetBIOS :

Code de nom	Type	Informations obtenues
<hostname> <00>	UNIQUE	Hostname
<domain> <00>	GROUP	Nom de domaine
<hostname> <03>	UNIQUE	Service Messenger en cours d'exécution pour l'ordinateur
<username> <03>	UNIQUE	Service Messenger en cours d'exécution pour l'utilisateur connecté
<hostname> <20>	UNIQUE	Service serveur (Server service) en cours d'exécution
<domain> <1D>	GROUP	Nom du navigateur maître (master browser) du sous-réseau
<domain> <1B>	UNIQUE	Nom du navigateur maître de domaine = contrôleur de domaine principal (PDC)
<domain> <1E>	GROUP	Élections du service Browser

2.2 Utilitaire Nbtstat

nbtstat est un utilitaire Windows de dépannage de la résolution de noms NetBIOS. Il fournit : les statistiques du protocole **NetBT** (NetBIOS over TCP/IP), les tables de noms NetBIOS (locales et distantes) et le **cache de noms NetBIOS**.

Syntaxe : nbtstat [-A <IPaddress>] [-a <remotename>] [-c] [-n] [-r] [-R] [-RR] [-s] [-S] [<interval>] [-?]

Table 4.3 — Paramètres Nbtstat :

Paramètre	Fonction
<remotename>	Affiche la table de noms NetBIOS d'un ordinateur distant (par nom NetBIOS)
-A <IPaddress>	Affiche la table de noms NetBIOS d'un ordinateur distant (par adresse IP)
-c	Liste le contenu du cache de noms NetBIOS (noms + IP résolues)
-n	Affiche les noms enregistrés localement par les applications NetBIOS (serveur, redirector)
-r	Affiche un compteur de tous les noms résolus par broadcast ou serveur WINS
-R	Purge le cache de noms et recharge les entrées #PRE du fichier Lmhosts
-RR	Libère et ré-enregistre tous les noms auprès du serveur de noms
-s	Liste la table des sessions NetBIOS en convertissant les IP de destination en noms
-S	Liste les sessions NetBIOS courantes et leur état avec les IP
<interval>	Ré-affiche les statistiques à intervalle donné
-?	Aide

Exemple clé : `nbtstat -a <IP de la machine distante>` → obtient la table de noms NetBIOS d'un ordinateur distant.

2.3 Outils d'énumération NetBIOS

- **NetBIOS Enumerator** (<https://nbtenum.sourceforge.net>) — énumère noms NetBIOS, noms d'utilisateurs, noms de domaine et **adresses MAC** pour une plage d'IP donnée.
- **Nmap** (NSE script `nbstat.nse`) — récupère les noms NetBIOS et adresses MAC d'une cible : `nmap -sV -v --script nbstat.nse <IP cible>` et `nmap -sU -p 137 --script nbstat.nse <IP cible>`.
- **Global Network Inventory** (<https://magnetosoft.com>)
- **Advanced IP Scanner** (<https://www.advanced-ip-scanner.com>)
- **Hyena** (<https://www.systemtools.com>)
- **Nsauditor Network Security Auditor** (<https://www.nsauditor.com>)

2.4 Énumération des comptes utilisateurs (suite PsTools)

- **PsExec** — remplaçant léger de Telnet : exécute des processus sur d'autres systèmes sans installer de client ; ouvre des invites de commande interactives distantes. Syntaxe : `psexec [\\computer[...]] | @file [-u user [-p psswd]] [-s] [-i] [-c executable] [-w directory] [-d] cmd [arguments]`.
- **PsFile** — affiche les fichiers ouverts à distance sur un système et peut les fermer par nom ou par identifiant. Syntaxe : `psfile [\\RemoteComputer [-u Username [-p Password]]] [[Id | path] [-c]]`.
- **PsGetSid** — traduit les **SID** en nom d'affichage et inversement ; fonctionne avec les comptes intégrés, de domaine et locaux. Syntaxe : `psgetsid [\\computer[...]] | @file [-u username [-p password]] [account|SID]`.
- **PsKill** — termine des processus locaux ou distants (par ID ou nom de processus), sans installer de client. Syntaxe : `pskill [\\computer [-u username] [-p password]] <process name | process id>`.
- **PsInfo** — collecte des informations clés sur les systèmes locaux ou distants : type et propriétaire du système, nombre et type de processeurs, mémoire physique, date d'installation, date d'expiration (versions d'évaluation). Syntaxe : `psinfo [\\computer[...]] | @file [-u user [-p psswd]] [-h] [-s] [-d] [-c] [-t delimiter] [filter]`.
- **PsList** — affiche les informations CPU/mémoire et les statistiques des threads.
- **PsLoggedOn** — affiche les utilisateurs connectés localement et les utilisateurs connectés via des ressources. Définit un utilisateur « connecté localement » comme celui dont le profil est

chargé dans le registre (scan de HKEY_USERS). Utilise l'API **NetSessionEnum** pour les connexions par partage de ressources. Syntaxe : `psloggedon [-] [-l] [-x] [\\computername | username]`.

- **PsLogList** — clone de `elogdump` : vide le contenu d'un **Event Log** local ou distant, avec connexion aux systèmes distants. Par défaut : affiche le **System Event Log** local. Syntaxe : `psloglist [...] [-s [-t delimiter]] [-m #] [-n #] [-h #] [-d #] [-w] [-c] [-x] [-r] [-a mm/dd/yy] [-b mm/dd/yy] [-f filter] [-i ID[,...]] [-e event source[,...]] [-o event source[,...]] [-q event source[,...]] [-l event log file] <eventlog>`.
- **PSPasswd** — change le mot de passe d'un compte sur des systèmes locaux ou distants ; utilise les API de réinitialisation de mot de passe Windows (pas de mot de passe en clair sur le réseau). Syntaxe : `pspasswd [\\computer[...]] | @file [-u user [-p psswd]] Username [NewPassword]`.
- **PSShutdown** — arrête ou redémarre un ordinateur local ou distant. Syntaxe : `psshutdown [\\computer[...]] | @file [-u user [-p psswd]] [-s|-r|-h|-d|-k|-a|-l|-o] [-f] [-c] [-n s] [-t nn|h:m] [-e [u|p]:xx:yy] [-m "message"]`.

2.5 Énumération des partages avec Net View

La commande **Net View** affiche la liste des ordinateurs d'un groupe de travail ou les ressources partagées disponibles sur un ordinateur donné.

Commande	Effet
<code>net view \\<computername></code>	Affiche les ressources partagées d'un ordinateur spécifique (nom ou IP)
<code>net view \\<computername> /ALL</code>	Affiche tous les partages (y compris les partages cachés : ADMIN\$, C\$, IPC\$, NETLOGON, SYSVOL)
<code>net view /domain</code>	Affiche tous les partages du domaine
<code>net view /domain:<domain name></code>	Affiche les partages du domaine spécifié

2.6 Énumération NetBIOS assistée par l'IA

Les attaquants utilisent des prompts ChatGPT (« Perform NetBIOS enumeration on target IP... », « Enumerate NetBIOS on target IP ... with nmap ») qui génèrent et exécutent automatiquement des commandes :

- `nbtscan <IP>` — analyse NetBIOS de la cible (noms, utilisateur, serveur, adresse MAC).
- `nmblookup -A <IP>` — obtient les noms NetBIOS associés (option `-A`).
- `nmap -sU -p 137 --script nbstat.nse <IP>` — énumère les services NetBIOS avec le script NSE `nbstat`.

Objectif 03 — Techniques d'énumération SNMP et LDAP

3.1 Énumération SNMP (Simple Network Management Protocol)

SNMP (protocole simple de gestion de réseau) est utilisé par les **administrateurs réseau** pour **surveiller et gérer** les équipements connectés (routeurs, commutateurs, serveurs, imprimantes, etc.) à distance.

- **Ports** : UDP 161 (agent SNMP), UDP 162 (réception des notifications/traps SNMP par le gestionnaire).
- **SNMP Agent** : logiciel exécuté sur l'équipement géré ; collecte les informations sur la **MIB** (Management Information Base) locale et répond aux requêtes du gestionnaire.
- **SNMP Manager** : gère la collecte, le stockage et le traitement des informations de gestion ; interroge les agents via l'API SNMP.
- **SNMP Manager MIB** : base de données d'objets locaux du gestionnaire.

Table 4.8 — Ports, versions et types de données SNMP :

Item	Détail
Ports	UDP 161 (port agent) et UDP 162 (port trap/notifications)
Versions	SNMPv1, SNMPv2c, SNMPv3
Types de données (PDU)	Get Request, GetNext Request, Set Request, GetBulk Request, Response, Inform Request, Trap

Traps SNMP : lorsqu'un événement se produit (ex. : changement de statut), l'agent envoie de manière **asynchrone** un message **Trap** au gestionnaire. Les **Trap PDUs** sont envoyés depuis le port 162.

PDUs SNMP :

Type de PDU	Rôle
Get Request	Le gestionnaire demande les informations de l'agent
GetNext Request	Le gestionnaire récupère l'itération suivante de la MIB
Set Request	Le gestionnaire modifie la valeur de l'objet de l'agent
GetBulk Request	Version SNMPv2 : permet de récupérer plusieurs objets en un seul message
Response	L'agent répond avec les informations demandées
Inform Request	Notification envoyée par un gestionnaire à un autre gestionnaire (accusée)
Trap	Notification non sollicitée envoyée par l'agent (non accusée)

SNMPv3 : apporte des améliorations de sécurité : authentification, intégrité et **chiffrement** des messages. Les **Notifications** SNMPv3 sont prises en charge et peuvent inclure des informations de **chiffrement et d'authentification**.

Community strings (chaînes de communauté)

- Le **community string** SNMP agit comme un **mot de passe**.
- Les équipements utilisent des community strings par défaut faciles à deviner : **public** (lecture seule) et **private** (lecture/écriture).
- Les attaquants l'utilisent pour accéder aux informations de l'équipement : tables de routage, listes d'utilisateurs, ressources partagées, etc.

Requêtes SNMP : - `snmputil get <host> <community> <OID>` — récupère la valeur d'un objet OID spécifique. - `snmputil walk <host> <community> <OID root>` — parcourt récursivement les objets de la MIB à partir de la racine OID.

Outils d'énumération SNMP

- **SnmpCheck** (<https://hakin9.org>) — interroge les OIDs : version de l'équipement, services (utilisateurs, informations d'authentification), interfaces réseau (adresses, masque, MTU), table de routage.
- **MIB Browser** (<https://www.ireasoning.com>) — parcourt les MIB via une interface GUI (pas de dépendance API).
- **OpUtils** (<https://www.manageengine.com>) — gestion d'adresses IP et de ports.
- **SolarWinds IP Address Manager** (<https://www.solarwinds.com>) — gestion d'adresses IP et de configuration DNS/DHCP.
- **Network Performance Monitor** (<https://www.solarwinds.com>)
- **snmpwalk** (sous Linux, paquet `snmp`) — parcourt la MIB : `snmpwalk -v1 -c public <IP cible> ...` ; la version 2c utilise le protocole GetBulk. Exemple : `snmpwalk -v1 -c public`


```
192.168.33.10 .1.3.6.1.2.1.1.1.0 et snmpwalk -v1 -c public 192.168.33.10  
.1.3.6.1.2.1.25.1.1.0.
```

Scripts Nmap pour SNMP

- `snmp-sysdescr.nse` — récupère la **description du système** (fabricant et version de l'équipement) : `nmap -sU -p 161 --script snmp-sysdescr <IP cible>`.
- `snmp-processes.nse` — énumère les **processus** en cours d'exécution : `nmap -sU -p 161 --script snmp-processes <IP cible>`.
- `snmp-netstat.nse` — liste les **connexions réseau** de la machine cible.
- `snmp-interfaces.nse` — liste les **interfaces réseau** et les adresses IP.
- `snmp-brute.nse` — **brute-force** les community strings (SNMP version 1) : `nmap -sU -p 161 --script snmp-brute <IP cible>`.

3.2 Énumération LDAP (Lightweight Directory Access Protocol)

LDAP est un **protocole d'accès à un annuaire** (directory service). Une information **DN** (Distinguished Name) identifie de manière unique une entrée dans un annuaire : elle est composée de RDN (Relative Distinguished Name) séparées par des virgules, ex. `CN=users,DC=htb,DC=local`.

- **Annuaire** : ensemble structuré d'enregistrements (ex. : annuaire téléphonique, base de données LDAP).
- **DSA (Directory System Agent)** : composant serveur qui fournit l'accès à un annuaire.
- **LDAP** utilise une structure de données dérivée du **X.500** et un codage **BER** (Basic Encoding Rules) pour transmettre les messages.
- **Ports** : TCP **389** (LDAP), TCP **636** (LDAPS, LDAP over SSL/TLS).
- **Annuaire de base** : `LDAP://HostName[:PortNumber][/DistinguishedName]`.
- La **découverte** (discovery) d'un LDAP se fait via `dc=`, `dc=htb`, `dc=local` etc.
- Les attaquants ciblent LDAP pour obtenir : des informations sur le réseau (IP, nom d'hôte), des détails sur l'organisation, et des comptes utilisateurs.

Outils d'énumération LDAP

- **Softerra LDAP Administrator** (<https://www.ldapadministrator.com>) — contient les services **LDAP Administrator**, **LDAP Browser** et **LDAP Search**. L'outil **LDAP Browser** présente l'annuaire dans une arborescence similaire à l'Explorateur Windows.
- **LDAP Admin Tool** (<https://www.ldapsoft.com>) — ajoute/modifie/supprime des objets dans un annuaire.
- **LDAP Account Manager** (<https://www.ldap-account-manager.org>)
- **Python LDAP** (module `ldap3/python-ldap`) — scripts d'énumération écrits en Python.
- **ldapsearch** (CLI) — récupère des entrées depuis un serveur LDAP. Syntaxe : `ldapsearch -h <IP> -x -b "DC=htb,DC=local" '(objectclass=*)'`.
- `-h` : serveur hôte ; `-x` : authentification simple ; `-b` : base de recherche (DN) ; `'(objectclass=*)'` : filtre pour lister toutes les entrées.

Scripts Nmap pour LDAP

- `ldap-search.nse` — recherche les **informations de l'annuaire** : `nmap -sV --script ldap-search <IP cible>` (ex. : `nmap -sV -p 389 --script ldap-search 192.168.33.10`).
- `ldap-rootdse.nse` — récupère le **RootDSE** (informations racines de l'annuaire, sous-ensemble des ressources).
- `ldap-brute.nse` — **brute-force** les attributs d'authentification de l'annuaire (noms d'utilisateurs/passwords).

Exemple de script Python (enum_ldap_users.py) : crée une connexion LDAP (`ldap3.Connection`), lie avec un domaine administrateur via NTLM, puis interroge le catalogue global (port 3268) pour lister les utilisateurs, les machines et les noms d'ordinateurs de la base : (`objectClass=person`) et (`objectClass=computer`).

Objectif 04 — Techniques d'énumération NTP et NFS

4.1 Énumération NTP (Network Time Protocol)

NTP est un protocole réseau permettant la **synchronisation des horloges** des ordinateurs (utilisé par les serveurs NTP).

- **Port : UDP 123.**
- Envoyer des requêtes à un serveur NTP permet à un attaquant d'obtenir des informations **sensibles** : liste des clients NTP, horodatages des événements système (birthdays internes du réseau)...
- NTP peut être utilisé pour :
- Découvrir l'**état du système** et la **version** du matériel/logiciel.
- **Mettre à jour le temps** du système pour des attaques (ex. : dater des événements, casser des protections temporelles).
- Connaître les **systèmes clients** qui se synchronisent.
- Avec NTP, la **falsification de serveur** (spoofing) est difficile car le protocole **ignore la latence**.

Outils de requête NTP (commande ntpq sous Linux) :

Outil / Commande	Rôle
ntpd	Synchronise l'heure du système avec un serveur NTP distant
ntptrace	Suit la chaîne de serveurs NTP jusqu'à sa source (détermine où un hôte obtient son heure)
ntpd	Interroge le démon ntpd (daemon) pour obtenir l'état, les pairs, la version
ntpq	Interroge le démon ntpd : <code>ntpq -c rv -h <IP></code> affiche la version NTP ; <code>ntpq -c version</code> affiche la version du client

Remarque : de nombreuses distributions Linux récentes remplacent ntpd par **chronyd** (paquet chrony) qui utilise le protocole NTP. Outil de remplacement : `chronyc` (interface en ligne de commande pour interroger chronyd).

4.2 Énumération NFS (Network File System)

NFS permet de **monter des systèmes de fichiers** situés sur des hôtes distants, comme s'ils étaient locaux.

- **Port : TCP 2049** (NFS). La configuration des exports est dans `/etc/exports`.
- `/etc/exports` : définit les répertoires partagés, les permissions (lecture/écriture) et les hôtes autorisés à y accéder.
- Une mauvaise configuration des exportations NFS donne aux attaquants un **contrôle à distance** des systèmes de fichiers, une **escalade de privilèges** et des **backdoors**.
- **RPC (Remote Procedure Call)** : protocole de communication utilisé par NFS (et d'autres services) pour exécuter des appels à distance.

Commandes : - `rpcinfo -p <IP>` — liste les **programmes RPC** en cours d'exécution et leurs versions sur la cible (détecte les services NFS, Rstat, mount, etc.). - `showmount -e <IP>` — liste les **partages NFS exportés** (exports) disponibles sur la cible.

Outils : - **RPCScan** (<https://github.com/hegusung/RPCScan>) — vérifie les communications RPC et les vulnérabilités communes (mal configurées). Syntaxe : `python3 RPCScan.py --host <IP>` et `python3 RPCScan.py --host <IP> --enum`. - **SuperEnum** (<https://github.com/p4pentest/SuperEnum>) — script pour la reconnaissance : énumération DNS, brute-force sous-domaines, requêtes de mots de passe NFS, etc. Syntaxe : `./SuperEnum.sh <IP>`.

Objectif 05 — Techniques d'énumération SMTP et DNS

5.1 Énumération SMTP (Simple Mail Transfer Protocol)

SMTP est un protocole de messagerie pour l'envoi (et le relais) d'e-mails.

- **Ports** : TCP **25** (soumission standard), TCP **2525** et **587** (ports de soumission modernes utilisés par les clients de messagerie).
- Les attaquants énumèrent les comptes utilisateurs via les commandes internes SMTP : **VERFY**, **EXPN** et **RCPT TO** (commande SMTP).
- **VERFY** : demande au serveur de **vérifier** si un compte existe : `VERFY <username>`. Réponse : `250 OK` (le compte existe) ou `550 ...` (le compte n'existe pas).
- **EXPN** : développe une **liste de diffusion** (mailing list) : `EXPN <mailing list name>`.
- **RCPT TO** : définit le destinataire du message (utilisé dans la phase d'énumération) : `RCPT TO <username>`.
- Les commandes SMTP fonctionnent à travers des serveurs de messagerie tiers (ex. : les serveurs **Gmail**) qui exigent une authentification.

Requêtes SMTP : - `telnet <IP> 25` — connexion au port SMTP (ex. : `telnet 192.168.168.1 25`), puis `VERFY` / `EXPN`. - **smtp-user-enum.pl** (utilitaire Perl) — énumère les noms d'utilisateurs via la technique `VERFY/EXPN/RCPT`. Syntaxe : `perl smtp-user-enum.pl -M <Méthode> -U <Fichier d'utilisateurs> -t <IP cible>` (méthodes : `VERFY`, `EXPN`, `RCPT`).

Scripts Nmap pour SMTP :

Script	Rôle	Syntaxe
<code>smtp-commands.nse</code>	Affiche les commandes SMTP supportées	<code>nmap --script smtp-commands -p 25 <IP cible></code>
<code>smtp-open-relay.nse</code>	Vérifie si le serveur est un relais ouvert	<code>nmap --script smtp-open-relay -p 25 <IP cible></code>
<code>smtp-enum-users.nse</code>	Énumère les utilisateurs via <code>RCPT</code> , <code>VERFY</code> et <code>EXPN</code>	<code>nmap --script smtp-enum-users -p 25 <IP cible></code>

Metasploit (auxiliary/scanner/smtp/smtp_enum) — énumère les utilisateurs via le module `smtp_enum` :

```
use auxiliary/scanner/smtp/smtp_enum
set RHOSTS 192.168.33.36
set USER_FILE /root/users.txt
run
```

5.2 Énumération DNS

Transfert de zone DNS (Zone Transfer)

- La **zone DNS** contient l'enregistrement des **hôtes** (hosts), la **liste des sous-zones** (subzones) et les **IP correspondantes** pour la zone de domaine.
- Le **DNS Zone Transfer** est utilisé par les administrateurs pour **répliquer** les données DNS entre serveurs DNS.
- Si le serveur DNS est **mal configuré**, le transfert de zone peut être **mené par un attaquant** et révéler tous les **hôtes nommés**, les **sous-zones** et les **IP associées**.

Commandes de transfert de zone :

- **dig** (Linux) : `dig @<IP> domain AXFR` — ex. `dig @192.168.33.20 example.com AXFR`. Sous-requêtes : `dig @<IP> <domain> NS` (serveurs de noms), `dig @<IP> <domain> SOA` (enregistrement SOA).
- **nslookup** (Windows) : `nslookup`

```
server set type=any ls -d ``
```
- **dnsrecon -t axfr -d <domain>** (Linux) — reconnaissance DNS avec test de transfert de zone.

Cache Snooping (écoute du cache DNS)

Le **cache snooping** est une technique permettant de savoir **quels enregistrements DNS** le serveur DNS cible a récemment **mis en cache** pour une requête donnée.

- Le serveur résout les requêtes depuis le cache s'il y a un enregistrement, sinon il transmet la requête à un serveur parent.
- L'attaquant détecte si une requête donnée est déjà présente dans le **cache** du serveur : les sites récemment visités par les utilisateurs peuvent ainsi être identifiés.
- **Méthodes :**
- **Non-recursive method (RD=0)** : requête sans récursion (flag RD à 0). Si la réponse contient des enregistrements, la requête est dans le cache ; sinon, un enregistrement referral est renvoyé.
- **Recursive method (TTL)** : requête récursive sur une période → on observe la valeur du **TTL** décroître → l'enregistrement est en cache.

Commandes (dig) : - Sans récursion : `dig @<IP> <domain> A +norecurse +authority`. - Récursive : `dig @<IP> <domain> A +recurse +ttlid`.

Zone Walking (parcours de zone) avec DNSSEC

- Le **zone walking** est une attaque qui énumère les enregistrements DNS contenus dans une zone **DNSSEC** (DNS Security Extensions).
- Les enregistrements **NSEC** (Next Secure) de DNSSEC exposent l'**ordre canonique** des noms de la zone → l'attaquant peut **découvrir les enregistrements suivants**.
- **NSEC3** (version hachée) rend le zone walking **pratiquement impossible**.
- Outils : **ldns-walk** (Linux) et **dnsrecon -z** (`dnsrecon -z -d <domain>`).
- Commandes : `dig @<IP> <zone> NSEC` pour lister les NSEC records et parcourir la zone.

Outils d'énumération DNS

- **Amass** (<https://github.com/owasp-amass/amass>) — outil open source de l'OWASP pour le mapping des surfaces d'attaque externes. Fonctionnalités : analyse DNS, découverte d'infrastructure, récupération de données, tracking de certifications TLS/SSL, etc.

- Commandes : `amass enum -d <domaine>` (énumération), `amass enum -d <domaine> -passive` (passif), `amass enum -active -brute -d <domaine>` (actif + brute-force), `amass db -show -d <domaine>` (affiche les résultats de la base), `amass viz -d3 -d <domaine>` (visualisation graphique D3).
- **dnsenum** (<https://github.com/fwaeytens/dnsenum>) — énumère DNS : enregistrements, serveurs de noms, transferts de zone, brute-force sous-domaines, Google scraping.
- **dnsrecon** — reconnaissance DNS multi-fonctions.

Scripts Nmap pour DNS

Script	Rôle
<code>dns-brute.nse</code>	Brute-force les sous-domaines
<code>dns-recursion.nse</code>	Détecte les serveurs DNS qui acceptent la réursion
<code>dns-nsec-enum.nse</code>	Énumère les enregistrements de zone en utilisant NSEC (zone walking)
<code>dns-zone-transfer.nse</code>	Effectue un transfert de zone
<code>broadcast-dns-service-discovery.nse</code>	Découvre les services réseau via des requêtes multicast DNS

Objectif 06 — Énumération IPsec, VoIP, RPC, Unix/Linux et SMB

6.1 Énumération IPsec (Internet Protocol Security)

- **IPsec** est un protocole de sécurité qui fournit **authentification, intégrité et confidentialité** pour les communications IP (chiffrement des paquets).
- **Ports et composants :**
- **UDP 500** — ISAKMP/IKE (Internet Security Association and Key Management Protocol / Internet Key Exchange) : établissement, négociation, modification et suppression des **Security Associations (SA)** et des clés.
- **AH (Authentication Header)** — protocole d'authentification (protocole IP 51).
- **ESP (Encapsulating Security Payload)** — protocole de chiffrement (protocole IP 50).
- Les attaquants énumèrent IPsec pour obtenir des informations sur : le type de cryptographie, la version de VPN, le système d'exploitation de la passerelle, la configuration réseau, les utilisateurs VPN (par différences de temps de réponse) et les **clés partagées** (pre-shared keys) dans le mode **IKE Aggressive**.

Outil : ike-scan (<https://github.com/royhills/ike-scan>) — découverte, fingerprinting, et test de sécurité des passerelles IPsec/IKE. Fonctions : découverte de la passerelle, fingerprinting (système d'exploitation, pile réseau), test de l'**énumération des utilisateurs** et du **brute-force des PSK** (avec `psk-crack` pour casser la clé partagée). Syntaxe : `ike-scan -M <IP cible>` ; `ike-scan -M --auth=3 <IP cible>` ; `ike-scan -M -P <nom de fichier> <IP cible>`.

- **Nmap** : `nmap -sU -p 500 <IP cible>` — détecte le service ISAKMP/IKE ouvert.

6.2 Énumération VoIP (Voice over IP)

- **VoIP** (Voice over Internet Protocol) permet la **transmission de la voix** (et de la vidéo) sur des réseaux IP.
- **SIP (Session Initiation Protocol)** est un protocole de signalisation de niveau application utilisé pour la téléphonie IP.
- **Ports** : TCP/UDP **5060** (signalisation SIP non chiffrée) et **5061** (SIP over TLS, chiffrée).

- Les attaquants énumèrent SIP/VoIP pour découvrir : les extensions téléphoniques actives, les **versions des logiciels** (softphones), la configuration du réseau et des passerelles.

Outils :

- **svmap** (sipproxy) — découvre les services VoIP dans un réseau : `svmap <IP cible>`.
- **Metasploit — SIP options (auxiliary/scanner/sip/options)** — détecte les serveurs SIP actifs et collecte les informations d'en-tête : `use auxiliary/scanner/sip/options set RHOSTS 192.168.33.90 run`
- **Metasploit — SIP Enumerator (auxiliary/scanner/sip/enumerator)** — énumère les extensions VoIP : `use auxiliary/scanner/sip/enumerator set RHOSTS 192.168.33.90 set USER_FILE /root/users.txt run`

6.3 Énumération RPC (Remote Procedure Call)

- **RPC** (Remote Procedure Call) est un **protocole client-serveur** permettant à un programme d'exécuter des procédures sur des **machines distantes** comme s'il s'agissait d'appels locaux.
- L'**interface RPC** gère le nombre de ports par défaut. Le **portmapper** (rpcbind) écoute sur le **TCP/UDP 111**.
- Les attaquants énumèrent les services RPC pour connaître les versions des services et leurs vulnérabilités : services FTP, SSH, etc.
- **Commandes** : `rpcinfo -p <IP>` — liste les services RPC enregistrés et leurs ports.
- Les **communes RPC** : pour énumérer RPC, il suffit de **scanner les ports TCP/UDP** de la cible et de soumettre le résultat au **portmapper** (rpcbind).

6.4 Énumération Unix/Linux

- **Les bases de données de comptes Unix/Linux** : les fichiers `/etc/passwd` (comptes utilisateurs) et `/etc/shadow` (empreintes des mots de passe hachés), ainsi que les **noms de comptes** sont présents sur tous les systèmes Unix/Linux.
- Les attaquants utilisent des outils/scripts comme `finger` et les bases d'utilisateurs pour **énumérer les comptes** du système Linux : ex. `finger @<IP>`, `finger <username>@<IP>`.
- Le **banner grabbing** sur les services expose les versions des services → recherche de vulnérabilités connues.
- L'énumération Unix/Linux fournit : les noms d'utilisateurs, les groupes, les ports, les partages, la version du système.

6.5 Énumération SMB (Server Message Block)

- **SMB** est un protocole de partage de fichiers/réseau principalement utilisé dans les réseaux Windows (partage de fichiers, d'imprimantes, de ports série et communication entre processus).
- **Ports** : **TCP 445** (SMB direct), TCP 139 (SMB via NetBIOS).
- Les attaquants énumèrent SMB pour obtenir des informations sur les services de partage de fichiers, la liste des partages (y compris les partages administratifs), et préparer d'autres attaques.
- **Commandes/outils** : `net view`, `smbclient -L //<IP>` (liste les partages), `nmap --script smb-enum-shares`, `enum4linux`, **crackmapexec** (exécution de commandes et énumération).
- **Mots de passe forts** : SMB ne doit jamais fonctionner avec des mots de passe vides ; toujours utiliser des mots de passe forts (de préférence 12+ caractères) pour les comptes locaux et de domaine.

Objectif 07 — Contre-mesures d'énumération

7.1 Contre-mesures générales

- **Supprimer les périphériques et services non utilisés** — désactiver les services inutiles (RIP, SMB, telnet, etc.) pour réduire la surface d'attaque.
- **Changer les mots de passe par défaut** sur tous les équipements et services.
- **Utiliser des mots de passe forts** pour tous les comptes locaux et de domaine.
- **Restreindre les droits d'utilisateur** — appliquer le **moindre privilège** (least privilege).
- **Chiffrer le trafic** (VPN, SSH, TLS) pour protéger les données en transit.

7.2 Contre-mesures NetBIOS / SMB

- **Désactiver NetBIOS** s'il n'est pas nécessaire ; sinon, **bloquer les ports UDP 137, 138 et TCP 139, 445** au niveau du pare-feu.
- **Restreindre les partages réseau** et les sessions nulles (null sessions) ; configurer le « Network access: Do not allow anonymous enumeration of SAM accounts and shares ».
- **Désactiver les comptes par défaut** (Guest, etc.) et utiliser des mots de passe forts.
- **Surveiller les journaux** (logs) pour détecter des balayages nbtstat ou des connexions répétées.

7.3 Contre-mesures SNMP

- **Bloquer le port UDP 161** au niveau du pare-feu et des équipements réseau.
- **Changer les community strings** par défaut (public/private) et utiliser des strings **difficiles à deviner**.
- Utiliser **SNMPv3** (authentification et chiffrement) au lieu de SNMPv1/v2c.
- Restreindre l'accès aux agents SNMP aux seuls gestionnaires autorisés (liste blanche d'adresses IP).

7.4 Contre-mesures LDAP

- **Bloquer le port TCP 389** (et 636 si LDAPS non requis) au niveau du pare-feu.
- **Restreindre l'accès** à l'annuaire aux seuls utilisateurs/administrateurs autorisés.
- Utiliser **LDAPS** (636) avec certificats pour chiffrer les échanges et limiter l'énumération.

7.5 Contre-mesures DNS

- **Restreindre les transferts de zone** : autoriser le transfert uniquement vers les **serveurs de noms secondaires autorisés**.
- Utiliser **DNSSEC avec NSEC3** (hachage) pour empêcher le zone walking.
- Désactiver la **réursion** sur les serveurs de noms exposés et restreindre les requêtes par IP.

7.6 Contre-mesures SMTP

- **Restreindre l'usage des commandes VRFY, EXPN et RCPT TO** sur les serveurs de messagerie.
- Utiliser l'**authentification SMTP** et un relais contrôlé (pas de relais ouvert).
- **Bloquer le port TCP 25** si le serveur de messagerie n'est pas requis en écoute publique.

7.7 Contre-mesures NTP, NFS et RPC

- **NTP** : limiter l'accès aux serveurs NTP (whitelist IP), restreindre les requêtes d'information, et utiliser l'**authentification NTP** quand c'est possible.

- **NFS** : exporter uniquement les répertoires nécessaires dans `/etc/exports` avec les options de sécurité (`root_squash`, `no_world_writable`) et autoriser uniquement les hôtes de confiance.
- **RPC/rpcbind** : bloquer le port 111 et désactiver les services RPC non requis ; utiliser des pare-feux restrictifs.

7.8 Contre-mesures IPsec, VoIP et générales

- **IPsec** : utiliser des **clés pré-partagées (PSK) robustes** et ne jamais utiliser le mode IKE Aggressive avec des clés faibles ; mettre à jour les piles IPsec/VPN.
- **VoIP/SIP** : restreindre l'accès aux ports 5060/5061, utiliser SIP over TLS et authentifier les extensions.
- **Surveillance et hardening global** : auditer régulièrement les services exposés, maintenir les correctifs à jour, et détecter les balayages/énumérations via les logs (IDS/IPS).

Récapitulatif du Module 04

Points clés à retenir pour l'examen 312-50 :

Sujet	À retenir
Définition	L'énumération = extraction d'utilisateurs, machines, ressources, partages, services via des connexions actives et requêtes dirigées (intranet)
Ports importants	UDP 137/138, TCP 139/445 (NetBIOS/SMB) ; UDP 161/162 (SNMP) ; TCP 389/636 (LDAP) ; UDP 123 (NTP) ; TCP 2049 (NFS) ; TCP 25 (SMTP) ; TCP/UDP 53 (DNS) ; UDP 500 (ISAKMP/IPsec) ; TCP/UDP 5060/5061 (SIP)
NetBIOS	Nom = 16 caractères (15 + 1 type) ; <code>nbtstat -a/-A/-c/-n/-r/-R/-RR/-s/-S</code> ; codes : <code><00></code> hostname/domain, <code><03></code> messenger, <code><20></code> server, <code><1D></code> master browser, <code><1B></code> PDC
PsTools	PsExec, PsFile, PsGetSid, PsKill, PsInfo, PsList, PsLoggedOn, PsLogList, PsPasswd, PsShutdown
Net View	<code>net view \\<host> /ALL</code> (partages cachés ADMIN\$, C\$, IPC\$...), <code>/domain</code>
SNMP	Community strings public/private ; <code>snmpwalk -v1 -c public <IP></code> ; scripts Nmap <code>snmp-*</code> (sysdescr, processes, netstat, interfaces, brute)
LDAP	<code>ldapsearch -h <IP> -x -b "DC=htb,DC=local" '(objectclass=*)'</code> ; scripts <code>ldap-search</code> , <code>ldap-rootdse</code> , <code>ldap-brute</code>
NTP	<code>ntpddate</code> , <code>ntptrace</code> , <code>ntpd</code> , <code>ntp</code> ; remplacement : <code>chronyd/chronyc</code>
NFS/RPC	<code>rpcinfo -p <IP></code> , <code>showmount -e <IP></code> ; <code>/etc/exports</code> ; RPCScan, SuperEnum
SMTP	VERFY / EXPN / RCPT TO ; <code>telnet <IP> 25</code> ; <code>smtp-user-enum.pl</code> ; scripts <code>smtp-commands</code> , <code>smtp-open-relay</code> , <code>smtp-enum-users</code> ; Metasploit <code>smtp_enum</code>
DNS	Zone transfer (dig AXFR, nslookup ls -d, dnsrecon -t axfr) ; cache snooping (RD=0, méthode TTL) ; zone walking NSEC (NSEC3 l'empêche) ; Amass, dnsenum
IPsec	UDP 500 ISAKMP/IKE, AH (proto 51), ESP (proto 50) ; <code>ike-scan -M</code> ; <code>psk-crack</code> (mode IKE Aggressive)
VoIP	SIP 5060/5061 ; <code>svmap</code> ; Metasploit <code>sip/options</code> , <code>sip/enumerator</code>
Unix/Linux	<code>/etc/passwd</code> , <code>/etc/shadow</code> , <code>finger</code>
Contre-mesures	Désactiver services inutiles, bloquer les ports (137/138/139/445, 161, 389...), mots de passe forts, SNMPv3, restreindre les zone transfers, DNSSEC NSEC3, restreindre VRFY/EXPN, PSK robustes

Fin du cours Module 04 — Enumeration (CEH v13).

CEH v13 Dump — Module 04 : Enumeration

Exam-Style Practice Questions (312-50) — With Answer Key

60 multiple-choice questions based on Module 04 content. Answer key at the end.

Questions

Part A — Enumeration Concepts & NetBIOS (Q1-Q14)

- Q1. Enumeration** is best defined as: - A) The process of extracting user names, machine names, network resources, shares, and services from a system - B) The process of passively gathering open-source information about a target - C) The process of identifying open ports on a target network - D) The process of exploiting a known vulnerability on the target
- Q2.** Enumeration techniques operate in which environment? - A) The Internet (external network) - B) An intranet environment - C) A DMZ only - D) Cloud environments only
- Q3.** Which of the following is an information that attackers **enumeration** extracts from a target? - A) Routing tables and audit/service settings - B) Credit card numbers - C) Encryption keys of the OS - D) BIOS passwords
- Q4.** Which statement about the **legality of enumeration** is TRUE? - A) Enumeration is always legal - B) Enumeration may be illegal depending on the organization's policies and applicable laws - C) Enumeration is never monitored - D) Enumeration only becomes illegal after exploitation
- Q5.** During enumeration, an attacker who stumbles on an **IPC\$ share** typically: - A) Ignores it as it is not exploitable - B) Probes it to brute-force admin credentials and access the file system - C) Uses it to reset the machine's clock - D) Uses it to perform a zone transfer
- Q6.** A NetBIOS name is a unique ASCII string of **16 characters** where the **16th character** is reserved for: - A) The domain name - B) The service or name type - C) The MAC address - D) The operating system version
- Q7.** Which ports are used by NetBIOS? - A) TCP 445 only - B) UDP 137, UDP 138, and TCP 139 - C) UDP 161 and UDP 162 - D) TCP 389 and TCP 636
- Q8.** In the NetBIOS name code table, which code represents the **Server service** running on a host? - A) <hostname> <00> - B) <hostname> <20> - C) <hostname> <03> - D) <domain> <1E>
- Q9.** Which NetBIOS code identifies the **Primary Domain Controller (PDC)**? - A) <domain> <1D> - B) <domain> <1B> - C) <domain> <00> - D) <hostname> <03>
- Q10.** Which **nbtstat** option displays the **NetBIOS name table of a remote computer given its IP address**? - A) -a - B) -A - C) -c - D) -n
- Q11.** Which **nbtstat** option lists the contents of the **NetBIOS name cache**? - A) -c - B) -n - C) -r - D) -R
- Q12.** Which utility from the **PsTools** suite displays users connected both locally and via resource shares? - A) PsList - B) PsLoggedOn - C) PsInfo - D) PsGetSid
- Q13.** Which command shows **ALL shares of a computer, including hidden administrative shares** such as ADMIN\$, C\$, and IPC\$? - A) net view \\<computername> /ALL - B) net view /domain - C) net use \\<computername> - D) nbtstat -S

Q14. Which of the following is NOT a NetBIOS enumeration tool mentioned in the module? - A) NetBIOS Enumerator - B) Global Network Inventory - C) Advanced IP Scanner - D) OpUtils

Part B — SNMP & LDAP (Q15-Q27)

Q15. SNMP operates on which ports? - A) TCP 161 and TCP 162 - B) UDP 161 (agent) and UDP 162 (trap/notifications) - C) TCP 389 and TCP 636 - D) UDP 123 only

Q16. In SNMP, the **community string** acts as: - A) An encryption key - B) A password - C) A certificate - D) A routing metric

Q17. Which community strings are commonly used as **defaults** on SNMP devices? - A) `admin` and `root` - B) `public` (read-only) and `private` (read/write) - C) `user` and `password` - D) `snmp` and `trap`

Q18. Which SNMP PDU is used by the **manager to modify the value of an object** on the agent? - A) Get Request - B) Set Request - C) GetNext Request - D) Trap

Q19. Which SNMP PDU is sent **asynchronously by the agent** to report an event and is **NOT acknowledged**? - A) Response - B) Inform Request - C) Trap - D) GetBulk Request

Q20. Which version of SNMP provides **authentication, integrity, and encryption** of messages? - A) SNMPv1 - B) SNMPv2c - C) SNMPv3 - D) SNMPv2u

Q21. Which Nmap script is used to **brute-force the SNMP community strings**? - A) `snmp-sysdescr` - B) `snmp-brute` - C) `snmp-processes` - D) `snmp-interfaces`

Q22. Which Linux command **walks the MIB tree** of an SNMP device? - A) `snmpwalk` - B) `snmputil get` - C) `nmap -sT` - D) `ldapsearch`

Q23. LDAP servers typically listen on which ports? - A) UDP 137 and UDP 138 - B) TCP 389 (LDAP) and TCP 636 (LDAPS) - C) TCP 25 and TCP 587 - D) UDP 500 and UDP 4500

Q24. In LDAP, a **DN (Distinguished Name)** such as `CN=users,DC=htb,DC=local`: - A) Identifies the IP address of the server - B) Uniquely identifies an entry in a directory - C) Is the encryption certificate of the directory - D) Specifies the port number of the server

Q25. What is the correct `ldapsearch` syntax to list all entries of a directory base? - A) `ldapsearch -h <IP> -x -b "DC=htb,DC=local" '(objectclass=*)'` - B) `ldapsearch -p <IP> -s "DC=htb,DC=local" '*'` - C) `ldapsearch -h -x -b query` - D) `ldapsearch -d -b '(objectclass=*)'`

Q26. Which LDAP directory component is the **server-side component** that provides access to a directory? - A) DN - B) DSA (Directory System Agent) - C) RDN - D) BER

Q27. LDAP uses which encoding rules to transmit its messages? - A) Base64 - B) BER (Basic Encoding Rules) - C) DER only - D) UTF-16

Part C — NTP, NFS, RPC & Unix/Linux (Q28-Q42)

Q28. NTP operates on which port and protocol? - A) TCP 123 - B) UDP 123 - C) UDP 161 - D) TCP 389

Q29. Which NTP utility **traces the chain of NTP servers back to its source** to determine where a host obtains its time? - A) `ntpdate` - B) `ntptrace` - C) `ntpd` - D) `ntpq`

Q30. Which NTP tool has replaced `ntpd` on many modern Linux distributions and uses the `chronyc` command-line interface? - A) `ntpdate` - B) `chronyd` - C) `ptpd` - D) `openntpd`

Q31. NFS listens on which TCP port by default? - A) 389 - B) 2049 - C) 445 - D) 111

- Q32.** Which command lists the **RPC programs** running on a target host? - A) `rpcinfo -p <IP>` - B) `showmount -e <IP>` - C) `rpcinfo -e` - D) `showmount -a`
- Q33.** Which command lists the **NFS exports (shares)** available on a target host? - A) `rpcinfo -p <IP>` - B) `showmount -e <IP>` - C) `nfs ls -e <IP>` - D) `exportfs -v`
- Q34.** The NFS export configuration file is: - A) `/etc/nfs` - B) `/etc/exports` - C) `/etc/mtab` - D) `/etc/nfsconfig`
- Q35.** A misconfiguration of NFS exports can lead to: - A) Only a denial of service - B) Remote control of the file system, privilege escalation, and backdoors - C) Sniffing of clear-text emails - D) DNS cache poisoning
- Q36.** Which tool scans RPC services for common vulnerabilities? - A) RPCScan - B) SuperEnum - C) `nbtstat` - D) `svmap`
- Q37.** Which service listens on TCP/UDP **port 111** and is used to map RPC services to their ports? - A) NetBIOS - B) portmapper (`rpcbind`) - C) LDAP - D) NTP
- Q38.** Which files contain the **user accounts** and the **hashed passwords** on Unix/Linux systems? - A) `/etc/hosts` and `/etc/resolv.conf` - B) `/etc/passwd` and `/etc/shadow` - C) `/etc/group` and `/etc/nologin` - D) `/var/log/passwd` and `/etc/secret`
- Q39.** Which classic command is used to enumerate **user accounts** on Unix/Linux hosts? - A) `finger` - B) `showmount` - C) `svmap` - D) `snmpwalk`
- Q40.** Which command lists the **shared resources** on an SMB target from Linux? - A) `net view \<host>` - B) `smbclient -L //<IP>` - C) `nbtstat -S` - D) `rpcinfo -p <IP>`
- Q41.** SMB directly hosted on TCP uses which port? - A) 139 - B) 445 - C) 143 - D) 4450
- Q42.** Which of the following is NOT a recommended SMB countermeasure? - A) Using strong passwords (12+ characters) - B) Allowing empty passwords for local accounts - C) Disabling NetBIOS when not required - D) Blocking ports 139 and 445 at the firewall

Part D — SMTP, DNS, IPsec, VoIP & Countermeasures (Q43-Q60)

- Q43.** Which SMTP command is used to **verify whether a user account exists** on the mail server? - A) EXPN - B) VRFY - C) HELO - D) DATA
- Q44.** Which SMTP command **expands a mailing list**? - A) VRFY - B) EXPN - C) RCPT TO - D) RESET
- Q45.** During SMTP enumeration, a response of **250** to a VRFY request indicates: - A) The user account does not exist - B) The user account exists - C) The server is an open relay - D) The server is offline
- Q46.** Which Nmap script **enumerates users** on an SMTP server using RCPT, VRFY, and EXPN? - A) `smtp-commands` - B) `smtp-enum-users` - C) `smtp-open-relay` - D) `smtp-brute`
- Q47.** Which Metasploit auxiliary module is used to **enumerate SMTP users**? - A) `auxiliary/scanner/smtp/smtp_enum` - B) `auxiliary/scanner/smtp/smtp_relay` - C) `auxiliary/scanner/smtp/options` - D) `auxiliary/scanner/smtp/login`
- Q48.** Which DNS technique reveals **all named hosts, subzones, and their IP addresses** when a name server is misconfigured? - A) DNS cache snooping - B) DNS zone transfer - C) DNSSEC zone walking - D) DNS recursion
- Q49.** Which command performs a **DNS zone transfer** using dig? - A) `dig @<IP> <domain> AXFR` - B) `dig @<IP> <domain> TXT` - C) `dig -x <IP>` - D) `dig @<IP> <domain> +norecurse`

- Q50.** Which nslookup command sequence performs a **zone transfer** in interactive mode? - A) set type=any then ls -d <domain> - B) set type=soa then ls -t <domain> - C) set recurse then ls -e <domain> - D) set type=ns then ls -z <domain>
- Q51.** The **cache snooping** technique allows an attacker to determine: - A) The encryption keys of the DNS server - B) Which DNS records the target server has recently cached - C) The DNS server's IP address - D) The TTL of the root servers
- Q52.** Which method of cache snooping checks the **TTL decreasing** over time to confirm a cached record? - A) Non-recursive method (RD=0) - B) Recursive method (TTL) - C) The Traceroute method - D) The brute-force method
- Q53.** **DNSSEC zone walking** uses which record type to enumerate the records of a zone? - A) SOA - B) NSEC - C) AAAA - D) MX
- Q54.** Which DNSSEC mechanism makes **zone walking practically impossible**? - A) NSEC - B) NSEC3 - C) RRSIG - D) DS
- Q55.** Which OWASP tool is used for **DNS enumeration and mapping of external attack surfaces**? - A) Amass - B) dnsrecon - C) dnsenum - D) SuperEnum
- Q56.** IPsec's ISAKMP/IKE protocol operates on which port? - A) UDP 500 - B) TCP 500 - C) UDP 4500 - D) TCP 53
- Q57.** Which tool is used to **discover and fingerprint IPsec VPN gateways** and can crack pre-shared keys with psk-crack? - A) svmap - B) ike-scan - C) rpcscan - D) snmpwalk
- Q58.** VoIP/SIP signaling typically uses which ports? - A) UDP 500 and UDP 4500 - B) TCP/UDP 5060 and 5061 - C) TCP 22 and TCP 25 - D) TCP 139 and TCP 445
- Q59.** Which Metasploit auxiliary module **enumerates VoIP extensions**? - A) auxiliary/scanner/sip/options - B) auxiliary/scanner/sip/enumerator - C) auxiliary/scanner/voip/extensions - D) auxiliary/scanner/sip/register
- Q60.** Which of the following is an **effective countermeasure against DNS zone walking**? - A) Disabling DNSSEC entirely - B) Using DNSSEC with NSEC3 (hashing) - C) Allowing recursive queries from anyone - D) Increasing the DNS TTL to 86400

Answer Key

Part A

Q	Answer	Explanation
1	A	Enumeration extracts user names, machine names, network resources, shares, and services
2	B	Enumeration techniques operate in an intranet environment
3	A	Routing tables and audit/service settings are enumerated; along with shares, SNMP details, machine names, users/groups, applications/banners
4	B	Enumeration may be illegal; a proper authorization is always required
5	B	An IPC\$ share is probed to brute-force admin credentials and gain access to the file system
6	B	The 16th character of a NetBIOS name indicates the service or name type
7	B	NetBIOS uses UDP 137 (names), UDP 138 (datagrams), TCP 139 (sessions)
8	B	<hostname> <20> = Server service; <00> = hostname, <03> = Messenger
9	B	<domain> <1B> = Primary Domain Controller (PDC); <1D> = master browser

Q	Answer	Explanation
10	B	-A = remote name table by IP; -a = by NetBIOS name; -c = name cache; -n = local names
11	A	-c lists the NetBIOS name cache; -r counts resolved names; -R purges the cache
12	B	PsLoggedOn shows users connected locally and via resource shares (NetSessionEnum)
13	A	net view \\<host> /ALL shows all shares including hidden ADMIN\$, C\$, IPC\$
14	D	OpUtils is an IP/port management tool (SNMP section); NetBIOS tools: NetBIOS Enumerator, Global Network Inventory, Advanced IP Scanner, Hyena

Part B

Q	Answer	Explanation
15	B	SNMP uses UDP 161 (agent) and UDP 162 (traps/notifications)
16	B	The community string acts as a password
17	B	Default community strings: public (read-only) and private (read/write)
18	B	Set Request modifies the value of an object on the agent
19	C	Trap = asynchronous, unsolicited, and unacknowledged notification (sent to port 162)
20	C	SNMPv3 provides authentication, integrity, and encryption
21	B	snmp-brute.nse brute-forces SNMP v1 community strings
22	A	snmpwalk walks the MIB tree (e.g., snmpwalk -v1 -c public <IP>)
23	B	LDAP = TCP 389; LDAPS = TCP 636
24	B	A DN uniquely identifies an entry in a directory (RDN separated by commas)
25	A	ldapsearch -h <IP> -x -b "DC=htb,DC=local" '(objectclass=*)'
26	B	DSA (Directory System Agent) is the server-side component
27	B	LDAP uses BER (Basic Encoding Rules) to transmit messages

Part C

Q	Answer	Explanation
28	B	NTP operates on UDP 123
29	B	ntpttrace traces the NTP chain to its source
30	B	chronyd (package chrony) replaces ntpd; queried via chronyc
31	B	NFS uses TCP 2049 by default
32	A	rpcinfo -p <IP> lists the RPC programs and their ports
33	B	showmount -e <IP> lists the NFS exports
34	B	The NFS export configuration is stored in /etc/exports
35	B	Misconfigured NFS exports lead to remote control, privilege escalation, and backdoors
36	A	RPCScan checks RPC communications and common vulnerabilities
37	B	The portmapper (rpcbind) listens on TCP/UDP 111 and maps RPC services
38	B	/etc/passwd = user accounts; /etc/shadow = hashed passwords
39	A	finger enumerates user accounts on Unix/Linux hosts
40	B	smbclient -L //<IP> lists SMB shares from Linux
41	B	SMB directly hosted (without NetBIOS) uses TCP 445
42	B	Empty passwords are a weakness; strong passwords (12+) are required

Part D

Q	Answer	Explanation
43	B	VERFY verifies whether a user account exists
44	B	EXPN expands a mailing list
45	B	250 = the user exists; 550 = the user does not exist
46	B	smtp-enum-users.nse enumerates users via RCPT, VRFY, and EXPN
47	A	auxiliary/scanner/smtp/smtp_enum enumerates SMTP users in Metasploit
48	B	A DNS zone transfer reveals all named hosts, subzones, and IPs if misconfigured
49	A	dig @<IP> <domain> AXFR performs a zone transfer
50	A	set type=any then ls -d <domain> in nslookup
51	B	Cache snooping reveals which DNS records the target server has cached recently
52	B	The recursive (TTL) method observes the TTL decreasing to confirm the cached record
53	B	Zone walking uses NSEC records to enumerate the zone in canonical order
54	B	NSEC3 (hashing) makes zone walking practically impossible
55	A	Amass (OWASP) maps external attack surfaces and performs DNS enumeration
56	A	ISAKMP/IKE operates on UDP 500
57	B	ike-scan discovers/fingerprints IPsec gateways and cracks PSKs with psk-crack
58	B	SIP uses TCP/UDP 5060 (plain) and 5061 (TLS)
59	B	auxiliary/scanner/sip/enumerator enumerates VoIP extensions
60	B	DNSSEC with NSEC3 hashing prevents zone walking

Indicative scoring

- **50-60 correct:** excellent — ready for the exam
- **40-49:** good — review the missed sections
- **30-39:** average — restudy the course, then retry
- **< 30:** re-read the complete Module 04 course document

Dump generated from the content of CEH v13 Module 04 (Enumeration). In case of OCR transcription errors, the official EC-Council PDF remains the reference.